

被允许动的钱

金融科技的下一个十年

过去十年，AI 在金融业被允许动的钱一直是零。
这个数字正在离开零——而几乎没有人把它计入定价。

75%

机构已用 AI
但 17% 才是基础模型^[4]

2%

用例是完全自主决策
其余都有人在回路里^[4]

\$1.9T

一家公司的年支付量
执行权的规模基准^[16]

≈ 0

当前可无人复核托付的金额
本书的核心变量

这篇文章在论证什么

关于 AI 与金融，公开讨论几乎全部集中在一个问题上：模型什么时候能超过人类分析师。这是个错误的问题。金融业从来不缺聪明的判断，缺的是**敢把判断变成动作的授权**。

所以本书只跟踪一条线：**一个 AI 系统被允许在无人复核下动多少钱**——我称之为**可托付金额上限**。它今天在绝大多数机构里是零。但它正在离开零，而且离开的方式是分级跳的：每一级由一组具体的、可观察的条件解锁。

这条线比模型能力线更值得看：它**可验证**（招标文件与事故披露会把它写出来）、它**决定收入结构**（能动钱的系统按结果计价，不能动钱的按席位计价）、而且它**非线性**——解锁一级需要治理、责任与保险同时到位，因此长期停滞、然后突然跳跃。

全文分五章：建立趋势线、推演终局形态、拆解四条争夺战线、讨论监管入场方式，最后给出六个可证伪的赌注与跟踪清单。

本书的方法
不预测模型能力，只推演授权边界。凡涉及未来的段落都标注触发条件与证伪条件；读者可以按季度用新增事实自行修正。

证据分级
监管文件与审计年报优先；公司自报数据只用于确认方向，不进入判断；媒体估值一律不采用。全部来源见附录。

利益声明
本书不构成投资建议，不含未公开信息，所有公司事实均来自公开披露。

目录 · 五章加附录

章	标题	这一章要回答的问题	页
前言	一个一直是零的数字	为什么“模型多强”是个错误的问题，而“被允许动多少钱”不是	03
第一章	闭环的五级阶梯	可托付金额上限的五个等级，各自由什么解锁，现在走到哪一级	05
第二章	从执行体到金融操作系统	当机器成为客户，结算、身份与定价会被重排成什么样	12
第三章 a	争夺轨道	执行权为什么是唯一不会被模型进步稀释的资产	17
第三章 b	锁住账本	数据权利、权限与供应链集中：权限误用比判断失误更危险	21
第三章 c	可托付性问题	如何让一个你不完全理解的系统去动钱——这是产品问题	24
第三章 d	标准之争	谁定代理支付协议、责任划分与跨境互认，谁就收长期的租	28
第四章	监管入场的形态	不是禁止，而是把治理写进准入——以及这对产品意味着什么	32
第五章	六个赌注	如果你在 2026 年做产品，具体该押什么、什么时候认输	35
附录	跟踪清单与来源	该盯住的信号、术语口径、24 条来源与证据折价规则	37

怎么读这篇文章

如果你只有十分钟：读前言、第一章的阶梯图（第 06 页）、第五章的六个赌注。这三处包含了全部结论。

如果你是产品经理：第三章 c 和第四章最有用，它们讨论的是你明天就要写进 PRD 的东西——额度、熔断、审计事件和退出机制。

如果你想反驳我：每一章末尾都有“我可能错在哪里”，列出了最可能推翻该章结论的证据。请从那里开始。

关于书名
“被允许”三个字是本书的全部立场：决定金融科技下一个十年的不是能力的上限，而是授权的边界。这两者在公开讨论中经常被混为一谈。

一个一直是零的数字

2024 年，英国央行和金融行为监管局做了一次全行业调查：75% 的受访金融机构已经在使用 AI，另有 10% 计划在三年内采用。这个数字被广泛引用，通常用来证明“金融业已经全面拥抱 AI”。^[4]

但同一份调查里还有三个数字，几乎没有人引用。第一，基础模型只占全部用例的约 17%——四分之三的“AI 应用”仍然是十年前那套预测式模型。第二，55% 的用例含有某种程度的自动化决策，但**完全自主决策的只有 2%**。第三，62% 的用例被机构自己评为低重要性，只有 16% 被评为高重要性。^[4]

把这三个数字放在一起，得到的结论和“全面拥抱”正好相反：AI 已经渗透进金融业的**周边**，但还没有进入**核心**。它在写营销文案、在做客服问答、在辅助开发，但它不批贷款、不下单、不划账、不签申报表。

这不是因为模型不够聪明。在很多受监管环节，模型的判断质量早已超过初级人工。真正的障碍在别处：**没有人愿意为一个无法解释、无法追溯、无法赔付的系统承担后果。**

所以真正值得跟踪的变量不是模型能力，而是授权。具体说，是这个数字：

一个 AI 系统，在没有人逐笔复核的前提下，被允许动多少钱？

今天，在绝大多数金融机构里，这个数字是零。不是“很小”，是**零**：任何涉及资金、授信或申报的动作，都必须有一个自然人在某个环节签字，哪怕签字本身只是走个形式。

零是一个特殊的数字。它意味着这条曲线还没有开始，因此没有人给它建模，也没有人为它定价。市场目前给 AI 金融公司的估值逻辑，仍然建立在“节省了多少人力”上——这是把第三代产品按第二代的方式定价。

但零正在被打破。Stripe 披露其自适应受理能力在 2024 年恢复了创纪录的约 60 亿美元被误拒的合法交易，同比增长 60%；Radar 自称为用户平均减少 32% 的欺诈。^{[16][17][18]} Intuit 披露已有超过 300 万客户让 AI 代理替自己完成工作，历史重复使用率超过 85%。^{[19][20]} 蚂蚁推出支付 MCP 与 AI 钱包，意图明确指向把智能体接入资金动作。^{[14][24]}

这些都还是低金额、高频次、可回滚的动作。但它们的共同点是：**系统在没有人逐笔看的情况下做了决定，并且这个决定直接改变了钱的流向。**零已经不是零了。

这三个例子来自三种完全不同的公司：一家支付网络、一家财税软件公司、一家超级应用。它们没有共同的模型供应商，也不在同一个辖区。**共同点是都握有某种执行接口**——能力扩散是普遍的，授权扩散不是：授权只流向已经握有接口和责任能力的地方。

75%

已使用 AI

英国监管调查，2024，118 家机构。看起来像终局，实际是起点——它统计的是“用过”，不是“托付过”。^[4]

17%

基础模型占比

四分之三的用例仍是传统预测模型。生成式 AI 的渗透远没有叙事中那么深。^[4]

2%

完全自主决策的用例

另有 24% 是半自主——能自己做一部分决定，但关键或模糊的决策仍设计为由人介入。^[4]

为什么“零”这么重要

在自动驾驶里，对应的变量是“脱手时间”；在工业自动化里，是“无人干预运行时长”。金融业的对应物就是可托付金额。所有这类曲线的共同特征：长期贴地，然后分级跳。

已经发生的位移

误拒交易的自动恢复、银行流水的自动匹配、代理支付令牌——三者都是“系统改变了钱的流向”，只是金额小、可回滚。

三个例子的共同点

都不是模型领先者，都握有执行接口。这是本书的核心观察。

没有人把这件事计入定价

世界经济论坛估计，全球金融业的 AI 支出将从 2023 年的约 350 亿美元增长到 2027 年的约 970 亿美元。^[5] 这个数字经常被用来论证市场很大。但如果你相信可托付金额会离开零，这个预测其实是**严重偏低的**——因为它统计的是“买 AI 的钱”，而不是“AI 经手的钱”。

这两者的量级完全不同。一家支付公司一年处理 1.9 万亿美元。^[16] 如果其中哪怕万分之一的决策权从人转移到系统，对应的商业价值就不是软件许可费，而是这条链路上的**抽成权**。软件预算与流量抽成之间，隔着三到四个数量级。

这就是我说“没有人计入定价”的意思。今天的市场在为一个软件市场估值；如果这条趋势线成立，实际形成的是一个**基础设施市场**——像清算所、像卡组织、像交易所那样，按流量而不是按席位收费。

本书的三个前提

前提一：模型能力会持续商品化。我不假设任何一家公司在模型上取得持久领先。恰恰相反，本书的全部论证都建立在“模型会变成可替换输入”这个假设上。如果这个假设错了，本书的结论会显著弱化。

前提二：监管趋向收紧而非放松。中国 2026 年 6 月的 32 项指导意见、美国财政部 2026 年 2 月发布的 FS AI RMF（含 230 项控制目标）、欧盟的 AI Act 与 DORA，方向高度一致：按风险分级、覆盖全生命周期、要求可追溯。^[10]
^{[11][12][13]} 我假设这个方向延续。

前提三：责任不会消失。无论技术怎么变，金融业最终要回答“出事了谁赔”。任何绕开这个问题的产品设计，都会在进入核心流程时被挡住。

\$35B→\$97B

全球金融业 AI 支出

WEF：2023 实际 → 2027 预测。这是“买 AI 的钱”。^[5]

\$1.9T

单家公司年支付量

这是“AI 可能经手的钱”。两个口径相差三个数量级以上。^[16]

如果前提一错了

若某家公司在金融专用模型上建立起持久的、难以复制的优势，那么“模型是可替换输入”不成立，本书对控制点的估值会偏高。这是我认为最可能出错的地方。

如果前提二错了

若主要市场明显放松监管，先执行权与治理能力的溢价会被稀释，速度型玩家而非合规型玩家胜出。第四章会展开这种情形。

图 0.1 · 两种叙事的分歧点：市场在为哪一件事定价

看法	跟踪的变量	推出的市场形态	收费方式
主流叙事	模型能力、参数、基准分数	软件市场，按人头替代计价	席位、订阅、API 调用
本书叙事	可托付金额上限、授权深度	基础设施市场，按流量与责任计价	交易抽成、结果分成、治理订阅
分歧点	如果 AI 只能建议、不能执行，主流叙事正确；一旦它被允许无人复核地动钱，第二种叙事的量级就完全不同。		

这不是“哪一种更乐观”的问题。第二种叙事对绝大多数当前的 AI 应用公司其实更悲观——因为它意味着价值会向少数拥有执行权与责任能力的机构集中。

我可能错在哪里

最强的反驳是：金融业的授权边界不是技术问题，也不是治理问题，而是**制度惯性**问题——它可能几十年不动。历史上，金融业接受新技术的速度确实经常以十年计。如果这条曲线在 2030 年前仍然贴着零，本书的时间表就整体错了，尽管方向未必错。

证伪条件

到 2029 年底，若主要市场仍无任何一类金融动作被普遍允许在无人逐笔复核下执行（哪怕是小额、可回滚的），则第一章的阶梯外推失败。

第 一 章

闭环的 五级阶梯

模型能力的进步无法直接换算成金融业的变化，因为中间隔着一道闸门：授权。这一章把闸门本身量化——五个等级，每一级由一组具体条件解锁，以及我们现在究竟站在哪一级。

本章主张

到 2030 年，至少一类高频、可回滚的金融动作会在主要市场被普遍允许在无人逐笔复核下执行。这不需要模型出现任何突破，只需要治理、保险与责任划分三件事同时到位。

1.1

把“可托付”变成可数的量

1.2

每一级由什么解锁

1.3

现在走到哪一级

1.4

为什么是分级跳

1.5

外推与时间表

1.1 把“可托付”变成可数的量

自动驾驶的分级之所以有用，不是因为它精确描述了技术，而是因为它把一个连续的技术问题**翻译成了一个离散的责任问题**。L2 和 L3 的真正差别不在于车开得多好，而在于出事时谁负责：L2 是驾驶员，L3 是系统提供方。整个行业在这两级之间卡了很多年，卡住的从来不是感知算法。

金融业需要同样的分级，而且理由更充分——金融业的每一个动作本来就有明确的责任归属和审计要求。但至今没有一个被广泛接受的分级框架，讨论因此停留在“AI 能不能做投顾”这种无法证伪的问题上。

我提出一个五级框架。它的划分依据不是模型能力，而是三件事：**系统能不能自己产出结论、能不能自己执行、以及执行后由谁承担后果**。

L0 观察。系统只读取和整理，不产出面向业务的结论。报表生成、数据检索、文档归类都在这一级。绝大多数所谓“AI 转型”的第一年成果都停在这里。

L1 建议。系统产出结论，但每一条都必须由人逐条采纳。这是 2023 到 2025 年生成式副驾的标准形态。它的商业问题不是不好用，而是价值无法归因——最终决策仍然是人做的，你无法证明改善来自 AI。

L2 受限执行。系统在预设的额度、白名单与场景边界内自动执行动作，人事后抽检。**这是“零”被打破的那一级**：从这里开始，系统的输出直接改变了钱的流向。今天最前沿的产品正处在这一级的早期。

L3 有条件自治。默认自动执行，只有异常才触发人工介入；机构在制度上接受由系统承担常规决策，并为此配置准备金或保险。这一级还没有在受监管的核心金融流程中普遍出现。

L4 全自治。没有预设的额度边界，系统之间可以跨机构协商与执行。这一级在可预见的十年内不会成为主流，但它决定了终局的形态，因此值得单独讨论（见第二章）。

划分依据

不是“模型有多强”，而是三个可观察的事实：能否自主产出结论、能否自主执行、后果由谁承担。这三项都能在合同和事故披露里找到证据。

为什么不用“自动化率”

自动化率会把 L0 的报表生成和 L2 的自动放款混在一起。这两件事的商业与风险量级完全不同，混在一起的指标没有意义。

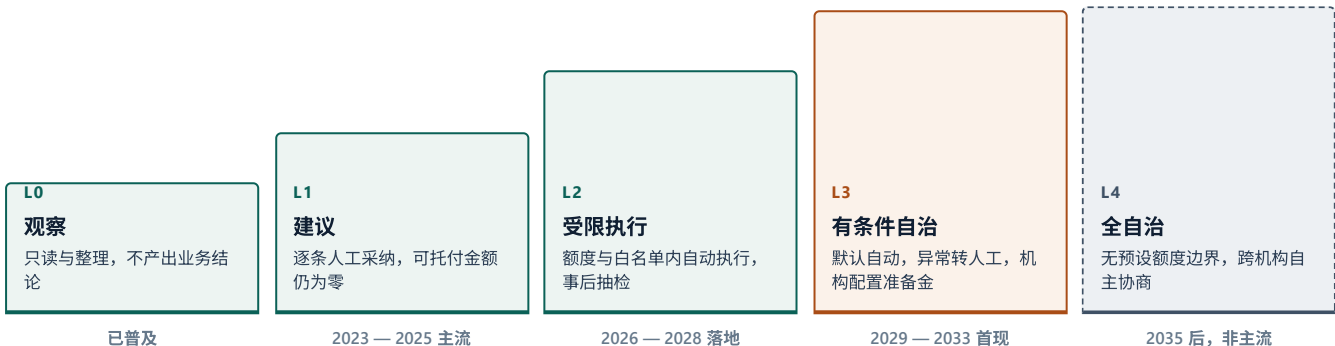
L1 的商业陷阱

副驾产品最容易做出来，也最难卖第二年：人做最终决策，因此 ROI 无法归因，续费谈判中永远处于劣势。这是第二代产品的结构性问题，不是执行问题。

L2 是分水岭

它是第一个让“结果定价”在逻辑上成立的等级——因为系统的动作与业务结果之间有了直接的因果链。

图 1.1 · 可托付金额上限的五级阶梯：每一级解锁一种商业模式



柱高表示可托付金额上限的相对量级，非线性刻度，用于表达“分级跳”而非具体数值。时间标注为本书推演，触发与证伪条件见 1.5 节。

1.2 每一级由什么解锁

如果只看技术，从 L1 到 L2 几乎不需要任何新东西——把模型的输出接到一个接口上就行了。事实上很多团队一周就能做出演示。但从演示到生产之间横着的不是技术差距，而是三类前提同时缺失。

技术前提通常最先满足，也最容易被误认为是唯一的前提。它包括：结论的置信度可估计、动作可回滚、全过程可留痕。这些不难做，问题是很多团队根本没做——因为演示阶段不需要。

治理前提才是真正的瓶颈。它要求：一套双方认可的评测集与人工基线、分级授权机制、熔断与回退路径、完整的审计事件链，以及供应商可被替换的证明。**这些没有一件能靠模型能力解决**，它们全都是产品设计与组织设计问题。

商业前提最容易被忽略：必须有一个愿意为结果付费、且有权转移部分责任的买方。买方是 IT 部门时，采购逻辑必然退回“节省了几个人力”；只有买方是业务负责人时，L2 以上的产品才有定价空间。

一周做出演示，两年进不了生产
这几乎是所有金融 AI 项目的共同经历。原因是演示只需要技术前提，生产需要三类前提同时满足。

治理不是合规部门的事
评测集、分级授权、熔断与审计事件全部是产品功能。把它们留给合规去“补”，等于把上线时间推迟一年。

图 1.2 · 每一级的解锁条件：技术、治理、商业三类前提

跃迁	技术前提	治理前提	商业前提	现状
L0 → L1	可用的通用模型与检索	数据权利清晰、输出留痕	有人愿为效率工具付费	已满足，普遍落地
L1 → L2	置信度可估计、动作可回滚	金标准评测集、人工基线、分级授权、熔断与回退、审计事件链	买方从 IT 转为业务负责人	当前瓶颈所在
L2 → L3	长期稳定性证据、漂移监控	责任归属制度化、事故披露机制、第三方独立验证	保险或准备金安排成型	零星试点，未标准化
L3 → L4	跨系统身份与权限互认	跨机构协议、拒付与赔付规则、争议仲裁机制	存在按流量收费的清算安排	标准尚未定型，见第三章 d

读法：每一行的三类前提是“与”关系，缺任意一项该级跃迁都不会发生。当前行业整体卡在第二行的治理前提上，而不是技术前提上。

这张表解释了一个反直觉的现象：**过去三年模型能力的巨大进步，几乎没有改变金融业的授权边界**。因为进步全部发生在技术前提那一列，而瓶颈从来在治理那一列。它也解释了为什么某些看起来技术平平的公司反而先跑通了闭环。

Stripe 的 Radar 在模型上未必领先，但它同时拥有网络级的结果标签、现成的争议处理流程和资金执行接口——三类前提天然齐备。^{[17][18]} Intuit 把注册会计师与税务专家做进产品，本质上是**用人工兜底买下了责任前提**，从而让 Agent 得以进入申报这种高责任场景。^{[19][20]}

由此得到一个对创业公司不友好的推论：三类前提中只有技术前提能靠团队独立获得，另外两类都必须与买方共建。**L2 以上的产品无法在实验室里做出来**。

这也解释了“设计伙伴”的特殊意义：你需要的不是需求反馈，而是一个愿意与你共担第一次事故的组织。

关键推论
下一阶段的赢家不会是模型最好的公司，而是三类前提最先齐备的公司。这决定了本书后面所有章节的分析框架。

反过来说
如果你现在做的是纯模型或纯应用层产品，这张表给出的是坏消息：你的技术优势正在贬值，而你缺的那两列不是靠加班能补上的。

1.3 现在走到哪一级

把六类主要金融场景放进这个框架，会看到一张分布极不均匀的图。它比任何总体采用率都更能说明产业的真实位置。

只有一个场景已经稳定运行在 L2：**支付风控**。它自动放行或拦截交易，人只做事后抽检与争议处理。原因不难理解——这个场景天然满足全部三类前提：结果标签实时回流、动作可回滚、争议流程本来就存在，而且买方就是业务本身。

客服与运营正在从 L1 向 L2 过渡，边界是“能改状态但不能动钱”：可以改地址、撤单、补发，但退款金额仍有额度限制。

财税与对账是下一个最可能跨过 L2 的场景：有客观对错、有系统记录、有专家兜底的行业传统。^{[19][20]}

投研与财富停在 L1，且短期内不会前进。障碍不是技术，是适当性义务与误导销售责任——这两项使“无人复核的建议”在法律上难以成立。

信贷与定价同样停在 L1：可解释性与公平性审查要求每一个特征都能被说明，这直接排除了大量端到端方案。

交易与资金是最保守的一格。它有沙箱、限额与多级复核，且尾部风险的量级远超其他场景——一次失败不是损失一单，而是可能引发市场层面的连锁反应。^[7]

把这六格连起来看，会浮现一条清晰的规律：**一个场景能走多远，取决于它的错误在多长时间内会被发现，以及发现后能不能撤销**。支付风控的错误在几秒内暴露、几分钟内可撤；投研建议的错误可能几个月后才显现，且无法撤销。这条规律比“风险高低”更能解释当前的分布。

它也给出了一个可操作的筛选器。评估任何一个金融 AI 机会时，先问三个问题：错误多久能被发现？错误能不能撤销？撤销的成本由谁承担？三个答案都清楚，这个场景就有机会跨过 L2；有一个答不上来，它就会一直停在建议层。

值得注意的是，这个筛选器与场景的“重要性”无关。反欺诈并不比投顾更简单，恰恰相反——但它的错误结构更友好。**选场景选的不是难度，是错误的可观测性**。

唯一稳定在 L2 的场景

支付风控。它是理解整条趋势线的样本：不是因为它最难，而是因为它的三类前提天然齐备。

“能改状态，不能动钱”

这是当前大多数受控执行 Agent 的实际边界。它是一条产品边界，也是一条责任边界。

投研为什么卡住

不是模型答得不好，而是适当性与误导销售责任要求存在一个可追责的自然人。制度不变，等级就不会变。

系统性风险的特殊性

FSB 单独提示了市场同质性风险：当大量机构使用相似模型，个体理性可能变成集体共振。这是交易场景比其他场景更保守的根本原因。^[7]

这张图容易被误读：格子越靠右不代表机会越大。恰恰相反，**停在 L1 且短期无法前进的场景最不值得投入**——你会耗尽力气去做一个永远无法归因、因而永远无法涨价的产品。真正的机会在“当前 L1、三年内可达 L2”那几格。

另一个观察：三个受阻场景卡住的原因各不相同——投研卡在**责任主体必须是自然人**，信贷卡在**决策必须可解释**，交易卡在**失败规模不可控**。它们不会同时解锁，把它们打包成“高风险场景”讨论会错过各自真正的触发条件。

不要按“风险高低”分组
三个受阻场景的阻塞原因各不相同，因此不会同时解锁，也不会因为同一件事而解锁。

最不值得投入的格子
停在 L1 且三年内不动的场景。你会做出一个永远无法归因、因而永远无法涨价的产品。

图 1.3 · 六类场景的当前等级与三年内可达等级

场景	L0	L1	L2	L3	L4	卡住它的那一件事
支付风控	已过	已过	当前	三年内	—	代理授权与拒付责任标准未定
客服与运营	已过	当前	三年内	—	—	越权操作与口径一致性
财税与对账	已过	当前	三年内	—	—	脏数据与跨系统割裂
投研与财富	已过	当前	受阻	—	—	适当性义务与误导销售责任
信贷与定价	已过	当前	受阻	—	—	可解释性与公平性审查
交易与资金	已过	当前	受阻	—	—	尾部风险与市场同质化共振

等级判断为本书研究判断，依据公开产品资料与监管文件；“三年内”表示触发条件满足时可达，不代表必然发生。

图 1.3b · 三个受阻场景各自需要什么才能解锁

场景	真正的阻塞点	解锁需要发生什么	谁能推动	本书判断
投研与财富	适当性义务要求存在可追责的自然人	出现“机器建议+持牌人复核”的标准 化责任分配，或监管明确豁免边界	证券监管与行业自律 组织	2030 年前难有实质变化
信贷与定价	每一个特征都必须可解释、可 公平性审查	可解释方法被审查机构正式接受，或 形成“传统模型定价+大模型辅助材 料”的双轨规范	银行业监管与消费者 保护机构	局部松动早于全面放开
交易与资金	失败规模不可控，且存在同质 化共振风险	建立模型多样性要求、集中度监测与 熔断联动机制	宏观审慎与市场基础 设施	会以额度与场景限制长期存在

三行的推动者完全不同，因此三条解锁路径彼此独立。对产品团队的含义是：不要指望某一次监管突破同时打开这三扇门。[7][10][11][12]

这三行还提示了一件事：**受阻不等于没有生意**。投研、信贷与交易场景仍然可以在 L1 上做出很大的业务，只是价值必须按人效计价，而不是按结果计价。混淆这两种定价逻辑，是这三个领域里最常见的商业误判。

受阻 ≠ 没生意
只是必须按人效计价，而不是按结果计价。用
错定价逻辑，产品再好也谈不下来。

1.4 为什么是分级跳，不是渐进

如果可托付金额是一条平滑上升的曲线，那么产业格局的变化会是温和的：每家公司按各自节奏往上爬，先发优势有限。但我认为这条曲线不是平滑的，而是长期贴地、然后台阶式跳跃。理由有三个，都与技术无关。

第一，责任是离散的。法律与合同不接受“百分之七十由系统负责”这种表述。责任要么在人这边，要么在系统提供方这边。这意味着每一次等级提升，都必须伴随一次明确的**责任转移**——而责任转移不会渐进发生，它需要一个具体的时点、一份具体的条款。

第二，保险是离散的。没有精算基础就没有保单，没有保单就没有机构敢把常规决策交出去。而精算需要事故数据，事故数据需要先有一批人在没有保险的情况下试过。这形成一个典型的启动问题：**要么长期停滞，要么在某个临界点上突然打开。**

第三，审计是离散的。审计师给不出“部分合规”的意见。一个系统要么能完整复现决策链，要么不能。而完整复现的能力需要一整套基础设施——事件总线、不可篡改日志、版本化的模型与提示词、权限快照。这套东西建成之前毫无用处，建成之后立刻可用。

历史上金融业出现过完全同构的过程。支付卡行业从磁条迁移到芯片，技术早就成熟，真正的迁移发生在**责任转移规则生效之后**——规则规定，若商户未升级受理终端而发生伪卡欺诈，损失由商户承担。技术准备了很多年，行为在规则生效前后的一两年内改变。

我认为 AI 在金融业的每一次等级提升，都会以同样的方式发生：先是长期的技术准备与零星试点，然后是一次监管或行业层面的责任划分，之后是快速的、几乎是被迫的普及。**因此，值得盯住的不是模型发布会，而是责任条款的措辞变化。**

三个离散性

责任、保险、审计。三者都不接受连续取值，因此叠加起来必然产生台阶。

保险的启动问题

没有事故数据 → 无法精算 → 无保单 → 无人敢用 → 无事故数据。打破这个循环通常需要一个愿意自保的大玩家，或者一次监管推动。

历史同构：支付卡的责任转移

芯片技术成熟多年，普及却集中在责任规则生效的前后。这说明改变行为的是规则，不是技术可用性。

该盯什么

不是模型基准分数，而是招标文件、保险条款和监管问答里关于“谁承担损失”的措辞。这些文本的变化领先于市场行为。

图 1.4 · 一次等级跃迁的完整结构：四个必须依次发生的事件

阶段	发生了什么	可观察的信号	典型时长
1 技术准备	能力可用、演示成熟、零星试点	产品发布、论文、演示视频	1 — 3 年，且早已开始
2 证据积累	少数机构自担风险跑出事故数据与基线	公司披露的效率数据、行业评测集出现	2 — 4 年，当前所处阶段
3 责任转移	监管或行业规则明确谁承担损失	招标条款、保险产品、监管问答的措辞变化	集中发生在 1 — 2 年内
4 快速普及	不升级的一方开始承担成本，迁移被迫发生	采购标准统一、供应商快速洗牌	1 — 3 年，且不可逆

本书认为，L1 → L2 的跃迁目前处在第 2 阶段末期；第 3 阶段的信号（保险产品与责任条款）是最值得提前布局的窗口。

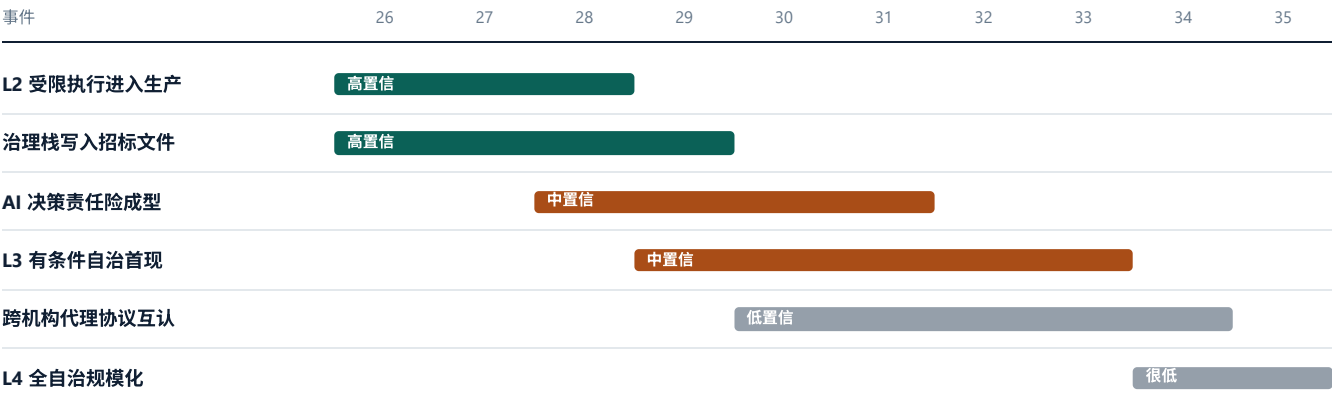
1.5 外推与时间表

把前面四节合起来，可以给出一张时间表。它不是预测而是**条件推演**：每一条都附触发与证伪条件，应在条件被观察到时才调整判断，而不是因为时间到了。

条件推演，不是预测
请按条件而非按时间修正判断。若触发条件迟迟不出现，正确的反应是推迟时间表，而不是放弃框架。

核心判断：**L1 到 L2 的跃迁已进入证据积累末期，责任转移最可能在 2027 到 2029 年间集中出现**。三方面信号同时在动——监管要求全生命周期留痕、大机构在招标中写入退出机制、首批为 AI 决策承担赔付的商业安排开始出现。

图 1.5 · 2026 — 2035 推演时间表



条形起止表示“最可能发生的窗口”，非确定性预测。置信度按现有公开证据的支撑强度划分，颜色对应本书全篇的置信度色标。

三个观察窗口

2026 — 2027：条款窗口。当“评测集归属”“审计留存期限”“退出与数据返还”在招标文件中作为独立条款出现，治理栈就已从加分项变成必选项。

条款窗口的具体动作
现在就把这三项做成产品功能并单独报价，比事后补便宜一个数量级。第四章会展开。

2027 — 2029：保险窗口。盯是否出现针对 AI 决策错误的独立险种及其定价依据。保单一旦可得，L2 到 L3 的经济学立刻成立。

本章的证伪条件
到 2029 年底，若主要市场仍无任何一类金融动作被普遍允许在无人逐笔复核下执行，或未出现任何针对 AI 决策的责任险产品，则本章的阶梯外推失败。

2029 — 2032：协议窗口。盯代理支付的授权、拒付与跨平台互认是否形成统一标准——决定终局分配的一战，见第三章 d。

保守均衡的可能性
不容低估。金融业历史上多次选择“技术可用但制度不采纳”。若如此，价值会继续留在人力替代，而不是流向执行权。

我可能错在哪里

最强的反驳是：**责任转移可能永远不发生**。金融业完全可以让 AI 永远停在 L1——收益更小，但制度成本为零。若行业采取这种保守均衡，本章的阶梯就只剩 L0 到 L1 有意义。

第二个反驳更技术性：可托付金额高度场景相关，同一系统在退款与放款场景的取值可能相差几个量级。因此 1.3 节用的是分场景等级表，而不是单一数字。

第三个反驳指向相反方向：跃迁可能**更快**。若某大型机构选择自保、吃下前几次事故，就能单方面绕过保险的启动问题，中置信窗口会整体提前约两年。

第二章

从执行体到金融操作系统

假设第一章的阶梯成立，L2 在若干场景落地。接下来发生的事情不是系统变得更聪明，而是它开始变宽——从一个场景扩到相邻流程，再扩到机构之间。这一章推演扩张的三级形态，以及当机器成为客户之后，结算、身份与定价会被重排成什么样。

本章主张

金融业不会出现一个统治性的“AI 大脑”，而会出现一个分层的操作系统：支付轨道负责执行，系统记录负责事实，治理层负责举证与追责。价值将向这三层集中，而不是向模型层集中。

2.1	2.2	2.3	2.4
三级扩张	当机器成为客户	结算、身份与定价的重排	谁会成为操作系统

2.1 三级扩张

一个系统在某个场景里跑通 L2 之后，团队的下一个动作几乎总是相同的：不是把这个场景做得更好，而是把它**接到隔壁**。这不是野心，是经济学——单场景的自动化收益很快见顶，而相邻流程的接入成本远低于从零获客。

第一级：单点闭环。在一个场景内完成读、判、做、审。这一级的边界很清楚：系统只碰一类单据、一类接口、一个责任人。它的价值上限也很清楚，大致等于该场景的人工成本加上错误成本。

第二级：跨流程。把相邻环节串起来——对账接到催收，催收接到计提，计提接到申报。价值不是相加而是相乘，因为消除的是环节之间的等待与信息损耗。但难点立刻变了：**不同流程的权限体系、身份口径和审批链通常不一致**，而这些在单点阶段是隐形的。

第三级：跨机构。一家机构的系统与另一家机构的系统直接交互——供应商的应收对上采购方的应付，商户的争议对上发卡方的规则。这一级的价值最大，但它需要的东西已经不在任何一家公司的控制范围内：**协议、责任划分和争议仲裁**。

三级之间不是线性的。每上一级，可实现的价值大约增加一个量级，治理复杂度也增加一个量级；而**治理复杂度的增长通常先于价值兑现**。这就是为什么大量团队在第二级卡住：他们低估了统一权限与身份所需的工作量，而这部分工作既不性感也不容易向客户收费。

扩张不是野心，是经济学
单场景自动化收益见顶得很快；相邻流程的接入成本远低于重新获客。所有跑通 L2 的产品都会向外扩。

第二级是坟场
跨流程扩张要求先统一身份、权限与审批链——这部分工作量巨大、不可见、且很难单独收费。大多数团队死在这里。

先于价值兑现的成本
治理复杂度在价值出现之前就要付。这解释了为什么这条路只有资源充裕或已有平台地位的玩家能走完。

图 2.1 · 三级扩张：范围、价值与新增难点

层级	作用范围	新增价值来源	新增难点	先决条件
一 单点闭环	一个场景、一类单据、一个责任人	人工成本 + 错误成本	置信度、回滚、留痕	技术前提即可
二 跨流程	同一机构内的相邻环节	消除环节间的等待与信息损耗	权限、身份与审批链不一致	统一的身份与权限模型
三 跨机构	不同机构的系统直接交互	消除对账、争议与信用摩擦	协议、责任划分与仲裁	行业级标准，见第三章 d

读法：从上到下，价值与治理复杂度大致各增加一个量级；但治理成本在价值兑现之前就要支付，这是扩张失败的主要原因。

有一个反直觉的推论：**最适合做第二级扩张的，往往不是最擅长做第一级的公司**。单点做得好靠的是场景理解，跨流程做得成靠的是身份与权限基础设施——后者更像平台能力，不像产品能力。这解释了为什么很多单点冠军最终被平台型玩家收编或绕过。

单点冠军的宿命
场景理解不会自动变成平台能力。第二级需要的是完全不同的一套工程与组织资产。

2.2 当机器成为客户

跨机构扩张会带来一个金融业从未认真处理过的问题：**发起交易的那一方可能不是人**。不是人在用工具，而是一个被授权的软件代理，代表某个人或某家企业，自主选择对手方、时机与金额。

这不是遥远的假设。共享支付令牌、代理商务协议、支付 MCP 与 AI 钱包，都是各家公司对同一个问题的早期回答：**如何让一个软件代理安全地花别人的钱**。^{[16][14][24]} 这些方案的技术细节各不相同，但它们要解决的是同一组问题。

身份认证的对象变了。传统的了解你的客户，验证的是一个自然人或法人。而代理不是法律主体，它是一条**委托链**：某个用户授权了某个企业，某个企业配置了某个代理，某个代理在某个时刻发起了某个动作。金融机构需要验证的是整条链的完整性与有效性，而不是链末端那个请求。

欺诈的形态变了。过去反欺诈识别的是“不该发生的交易”——盗刷、伪卡、账户接管。代理时代最难的一类是**越权的合法代理**：授权是真的，代理是真的，但它做的事超出了用户实际意图的范围。这类问题在技术上无法只靠交易特征识别，必须靠授权范围的显式表达。

议价方式变了。人会因为品牌、习惯和界面摩擦而留在一家机构；机器不会。当代理可以在几毫秒内比较十家供应商的费率与到账时间，**靠信息不对称与切换摩擦维持的利差会被系统性压缩**。这对以此为主要收入的环节是坏消息。

争议的归属变了。如果代理下错了单，过错在用户、在企业、在代理供应商，还是在接受这笔交易的机构？现有的拒付规则是围绕“持卡人未授权”设计的，它没有为“授权了但代理理解错了”预留位置。这是第三章 d 的核心议题。

KYC → KYA

需要验证的不再是一个主体，而是一条委托链：用户 → 企业 → 代理 → 动作。链上任何一环失效，整个授权就应当失效。

最难的一类欺诈

不是伪造，是“越权的合法代理”。授权真实、身份真实，但行为超出用户实际意图。交易特征识别不了这种问题。

利差压缩

机器不会因为界面好看而留下。凡是靠切换摩擦赚钱的环节，都会在代理普及后被重新定价。

拒付规则的空白

现有规则围绕“持卡人未授权”设计。“授权了但代理理解错了”这一类，目前没有对应条款。

图 2.2 · 人类客户与机器客户的六个结构性差异

维度	人类客户	机器客户	受影响最大的环节
身份	单一主体，可直接认证	委托链，需逐环验证与可撤销	KYC、账户开立
意图	隐含在行为中，事后推断	必须被显式表达为授权范围	授权与风控
频率与金额	低频、金额分散	高频、小额、可批量	清算与结算成本
比价行为	受品牌与摩擦影响	近乎完全理性、可即时路由	利差与费率
欺诈形态	身份伪造、账户接管	越权的合法代理	反欺诈模型
争议归属	规则成熟，判例充分	规则空白，责任链条不清	拒付与仲裁

六行中有五行指向同一件事：现有金融基础设施的默认假设是“对面是个人”。这个假设一旦松动，需要改的不只是风控模型。

2.3 结算、身份与定价的重排

如果机器客户成为常态，三样基础设施会先被重排。它们的共同点是：今天的设计都建立在“交易是人发起的、频率有限、单笔有一定金额”这个前提上。

结算。机器交易倾向于更小额、更高频、更碎片化。现有清算体系的单笔固定成本在面对这种流量时会变得难以承受——不是技术上做不到，而是费率结构不匹配。可能的应对有三种：批量净额化、账户内记账后定期清算、以及预置额度下的先执行后对账。**三种都指向同一个结论：谁持有余额，谁就获得新的经济利益。**

身份。需要的不再是一个身份，而是一份**可验证、可限定、可撤销的委托凭证**：它要能表达“这个代理可以在未来七天内，就这一类商品，累计不超过某个金额，向白名单内的对手方付款”。这类凭证的标准由谁定义，决定了未来谁在授权链的中心。

定价。当比价成本趋近于零，产品之间的差异会被压缩到少数几个可量化维度：费率、到账时间、成功率、争议处理效率。品牌与界面的溢价会显著下降。这对新进入者是好消息，对靠存量关系收费的机构是坏消息。

把三件事合起来看，可以得到一个关于价值转移的判断：**价值会从“接触用户的界面”转移到“承载额度与凭证的账户”，再转移到“定义授权语义的协议”**。界面会变得廉价，因为代理不需要界面；账户会变得重要，因为额度必须存放在某处；协议会变得关键，因为它决定了谁的授权被承认。

谁持有余额，谁获益
三种结算应对方式都会把资金沉淀在某个中间账户上。这是代理经济里最直接、也最容易被低估的经济利益。

委托凭证的四个要素
有效期、范围、限额、对手方白名单。缺任何一项，授权就无法被安全地自动执行。

界面的贬值
代理不需要好看的界面。以界面体验为核心壁垒的产品，在这一轮里处境最尴尬。

价值迁移的方向
界面 → 账户 → 协议。越靠后越难被替代，也越难被看见。

图 2.3 · 代理普及后的价值迁移：谁受益，谁受损

环节	今天靠什么赚钱	代理普及后	本书判断
前端界面与流量	获客、习惯、转化漏斗	代理绕过界面直接调用	显著受损
信息中介与比价	信息不对称与推荐位	比价成本趋近于零	显著受损
账户与额度持有	沉淀资金与备付	额度必须有处存放	受益
清算与轨道	按笔或按额收费	笔数大增，单笔变小	结构性受益，需改费率
授权与协议标准	目前几乎不收费	成为必经环节	最大受益方
争议与仲裁	成本中心	规则空白被填补后成为服务	由成本转为收入

本表为条件推演：其成立前提是代理发起的交易达到有意义的份额。若代理长期停留在辅助角色，表中判断整体不成立。

2.4 谁会成为操作系统

"操作系统"这个词被滥用了，所以需要有一个严格的定义。一个东西是操作系统，当且仅当它满足两个条件：**别人在它上面构建**，并且**它定义了权限模型**。第二条比第一条重要得多——真正的控制力来自"谁能做什么"由谁决定。

按这个标准，金融业里今天没有任何一个 AI 产品是操作系统。但有三类玩家正在各自的方向上逼近，而且它们逼近的是**不同的层**。

支付网络逼近执行层。它们已经拥有资金动作接口、跨商户的结果数据和现成的争议流程。它们缺的是对企业内部事实的掌握——它们知道钱怎么流，不知道账该怎么记。

系统记录厂商逼近事实层。财税软件、终端与数据平台掌握着业务事实的权威版本。它们缺的是执行接口——它们知道该做什么，但需要借道别人才能做成。

超级应用与生态逼近入口层。它们同时拥有场景、身份与支付，理论上最接近全栈。它们的问题不是能力，是**开放性**：一个封闭生态可以成为自己的操作系统，但很难成为行业的操作系统。

我的判断是：**不会出现单一的金融 AI 操作系统，而会形成三层分工**——支付轨道负责执行，系统记录负责事实，治理层负责举证与追责。这三层之间会有激烈的边界争夺，但没有一层能吞掉另外两层，因为它们的能力来源完全不同：一个来自牌照与网络，一个来自客户数据与迁移成本，一个来自监管认可与专业责任。

如果这个判断成立，那么最值得关注的其实是第三层。执行层和事实层都有明确的在位者，而**治理层今天几乎是空的**——没有人在系统性地把评测、日志、权限、退出做成可跨机构复用的产品。这是本书认为最被低估的位置。

我可能错在哪里

本章最脆弱的一环是"机器客户会达到有意义的份额"。如果代理长期只是人类的辅助工具、每一笔交易仍由人点击确认，那么 2.2 与 2.3 的推演都不成立，价值也不会从界面迁走。

第二个风险是三层分工可能不稳定。如果某个玩家同时拿下执行与事实两层——例如一家支付公司深度收购或整合财税软件——那么三层结构会塌缩成两层，治理层的独立价值也会随之减弱。

操作系统的严格定义

别人在它上面构建，且它定义权限模型。第二条才是控制力的来源。

三类逼近者，三个不同的层

支付网络缺事实，记录厂商缺执行，超级应用缺开放性。三者的短板都不是技术。

封闭生态的天花板

可以成为自己的操作系统，很难成为行业的操作系统。开放程度决定了它是平台还是围墙。

最被低估的位置

治理层。执行层与事实层都有强大的在位者，治理层今天几乎无人占据，而它是 L2 以上所有交易的必经环节。

本章证伪条件

到 2030 年，若代理发起并自动完成的交易在主要市场仍不足以形成独立的规则讨论（无专门的授权、拒付与仲裁条款），则本章推演失败。

争夺轨道

如果价值向执行层、事实层与治理层集中，那么接下来的十年就是围绕这三层的争夺。这一节讨论第一层，也是最容易被误判的一层：为什么执行权不会被模型进步稀释，以及谁已经握住了它。

本 节 主 张

模型进步降低的是判断成本，不是接入成本。接入成本由牌照、清算网络、争议流程和责任能力构成，这些东西不随算力下降而下降——因此执行权是唯一不会被技术进步稀释的资产。

a.1

为什么执行权不被稀释

a.2

四种控制权的收敛

a.3

中国的位置

a.1 为什么执行权不被稀释

过去三年，几乎所有与 AI 相关的成本都在下降：单位推理成本、微调成本、部署成本、乃至构建一个能用产品所需的人力。这种普遍的下降造成了一个错觉——**所有壁垒都会被技术进步侵蚀**。

但仔细看会发现，下降的只有一类成本：**判断成本**。让系统知道该做什么，变便宜了。让系统被允许去做，没有变便宜。

接入成本由四样东西构成，它们与算力毫无关系。**牌照**：发起资金动作通常需要资质，而资质的获取周期以年计。**清算网络**：接入需要对手方接受你，而对手方的接受取决于历史、规模与信任。**争议流程**：出错之后的处理能力是一整套组织能力，不是一个接口。**责任能力**：你得有资产负债表或保险去承担后果。

这四样东西的成本曲线是**平的甚至向上的**——监管趋严会让牌照更贵、让责任要求更高。于是出现一个剪刀差：判断成本快速下降，接入成本不降反升。**剪刀差的两侧，就是价值转移的方向**。

这解释了一个否则很难解释的现象。过去两年，模型能力最强的公司并没有在金融业获得对应的商业地位；反而是那些模型能力平平、但握有支付或账本接口的公司，把 AI 变成了收入。差别不在谁更聪明，在谁被允许动手。

网络的价值也体现在同一处。Stripe 称其网络上约 **92% 的交易来自它此前见过的卡**，模型训练于 70 万亿以上的数据点。^[18] 这种数据不是买得到的——它是执行权持续运行的副产品。**一家公司必须先被允许动手，才能积累起让它继续被允许动手的证据**。

由此可以推出一个对创业者相当残酷的结论：**如果你的产品价值完全来自判断质量，那么你正站在成本快速下降的那一侧**。你今天的优势会被下一代模型抹平，而你并没有在积累任何不随技术下降的资产。唯一的出路是尽快把判断接到某种执行或责任上——哪怕这意味着更慢、更重、更不性感。

两类成本
判断成本在崩塌，接入成本在上升。所有关于“壁垒会被侵蚀”的直觉，只对第一类成立。

接入成本的四个来源
牌照、清算网络、争议流程、责任能力。四者都以年为单位积累，且与算力无关。

剪刀差
监管趋严会让接入成本进一步上升。这意味着剪刀差还会扩大，而不是收敛。

给创业者的判据
问自己：我的优势会不会被下一代模型抹平？如果会，我在积累什么不随技术下降的资产？

图 a.1 · 两类成本的反向走向

成本类型	包含什么	近三年走向	未来走向	谁受益
判断成本	推理、微调、部署、构建产品的人力	快速下降	继续下降	所有人，因此不构成优势
接入成本	牌照、清算网络接受度、争议处理能力、责任承担	持平或上升	随监管趋严进一步上升	已在位者

这张表是本书全部结论的基础。如果判断成本停止下降，或接入成本开始崩塌，本书的分析框架需要整体重写。

a.2 四种控制权的收敛

把"接入成本"再拆细，可以得到四种可以分别持有、也可以被分别夺走的控制权。它们的组合决定了一家公司在这条产业链上能收租还是只能接单。

数据权是持续结果标签的所有权：数据随每一笔业务自动更新，停止经营它就立刻变旧。它与"买来的语料"有本质区别——后者是存量，前者是流量。

入口权是系统记录的位置：某类业务事实的权威版本存放在你这里，替换你需要迁移多年历史与流程配置。它的强度不由界面决定，由迁移成本决定。

执行权是不经第三方发起真实动作的能力。它是四者中最难获得、也最难被侵蚀的一项。

责任权是在出事后完整举证并承担损失的能力。它常被误认为是成本，实际上它是**进入核心流程的通行证**——没有它，前三项都只能停在建议层。

用这四项去看五家标杆，会发现一个有意思的分布：没有一家四项全强，但强项的组合方式决定了各自的天花板。

图 a.2 · 五家标杆各自握有哪几种控制权

公司	数据权	入口权	执行权	责任权	结构含义
Stripe	强	中	强	中	反馈闭环最短；弱在治理透明度与代理授权标准
蚂蚁集团	强	强	强	中	四权最齐；瓶颈在开放度与 AI 增量的独立披露
Bloomberg	强	强	弱	强	信任资产最强，但结论无法直接变成动作
Intuit	强	强	中	强	记录与责任双强，短板是全球化与标准化外延
同花顺	中	强	弱	中	有入口缺执行与责任；2025 年广告与互联网推广占其收入 57%，上限受制于流量变现 ^[23]

强弱为本书研究判断，依据公开披露的产品能力与业务结构，不构成评级。^{[14][16][19][21][23][24]}

从这张表能读出两条收敛路径。**第一条是"有执行、补事实"**：支付类玩家向系统记录延伸，方式通常是收购或深度集成财税、ERP、对账类产品。**第二条是"有事实、补执行"**：记录类玩家向资金动作延伸，方式通常是与持牌方合作或自建支付能力。

两条路径的难度并不对称。补事实需要买或建一套软件，昂贵但可预期；**补执行需要牌照、网络接受度与责任承担能力，很多时候有钱也买不到**。这意味着长期看，第一条路径的成功率更高——这对今天的记录类在位者是一个需要认真对待的风险。

存量与流量

买来的语料是存量，会贬值；业务回流的结果标签是流量，会增值。这是数据权的判定标准。

责任权被系统性低估

它看起来像成本中心，实际上是准入证。缺了它，再强的判断也只能停在建议层。

不对称的两条路

补事实是钱能解决的问题，补执行往往不是。记录类在位者的护城河没有看上去那么深。

a.3 中国的位置

把同一套框架套到中国市场，会得到一个结构清晰但不对称的画面：**执行权极强，事实层薄弱，治理层在建。**

执行权是中国最厚的一层。 移动支付的渗透深度、场景密度和身份绑定程度在全球范围内都属领先；Alipay+ 通过与本地钱包和各国二维码标准互通，把这套执行能力延伸到了境外受理侧。支付 MCP 与 AI 钱包等尝试，方向明确指向把智能体接进资金动作。^{[14][15][24]} 这是中国公司在本轮竞争中最真实的资产。

事实层是最薄的一层。 企业侧的系统记录高度分散：财税、ERP、供应链、银行流水分属不同厂商，且渗透率远低于成熟市场的对应产品。这直接导致跨流程扩张的成本更高——你想串起对账到申报，可能要对接五套互不兼容的系统。这也是中国 AI 交付偏项目制、毛利偏低的结构原因。

治理层正在被监管快速塑形。 2026 年金融监管总局的 32 项意见，明确了“谁使用谁负责”、自主可控，以及覆盖需求、数据、开发、部署、运行、退出的全生命周期管理。^[10] 这既是约束也是机会：**约束在于合规成本前置，机会在于它把治理能力变成了可以标价的产品。**

三层放在一起，给出的战略含义相当具体。中国公司在执行层已经领先，不需要再证明；在事实层追赶的性价比不高，因为那是长期积累；**真正值得抢的是治理层**——它刚刚被监管定义出来，还没有在位者，而且一旦成型就会成为所有跨机构交易的必经环节。

出海的逻辑也随之明确。直接复制国内的零售金融打法在多数市场行不通，因为缺牌照、缺关系、缺本地数据。但**跨境商户的支付、财资、风控与合规**是一个例外：这一段的执行权可以延伸，治理能力可以标准化，且本地持牌方有共同交付的动机。

我可能错在哪里

本节假设执行权可以跨境延伸。但支付出海的成功不必然转化为“代理执行权”的出海——后者涉及授权语义与责任划分，而这两件事在每个法域都不同，且高度政治化。如果代理支付标准最终按区域割裂，中国的执行权优势就会被锁在国内市场。

最厚的一层

执行权。这是过去十五年移动支付竞争留下的真实资产，不需要重新证明。

最薄的一层

企业侧系统记录。分散、渗透低、互不兼容，直接推高跨流程扩张成本，压低交付毛利。

被监管定义出来的新层

32 项意见把全生命周期治理写成了要求。要求即市场——它第一次让治理能力可以被单独标价。^[10]

出海的例外

跨境商户场景：执行权可延伸、治理可标准化、本地持牌方有合作动机。这是少数可复制的路径。

本节证伪条件

若到 2030 年，主要市场的代理支付授权标准彼此不互认，且跨境代理交易需逐一重新持牌，则执行权可延伸的假设失败。

锁住账本

争夺轨道的同时，另一场更安静的争夺正在进行：数据权利、访问权限与供应链集中度。这一层要锁住的不是模型权重，而是账本、日志与密钥——金融业真正怕的从来不是被偷走能力，是被误用权限。

本 节 主 张

金融 AI 最可能出现的系统性事故，不是模型判断错误，而是权限配置错误与第三方集中失效。前者是产品缺陷，后者是行业风险——而目前几乎没有人为后者定价。

b.1

三类必须锁住的东西

b.2

集中度：被忽略的系统性风险

b.1 三类必须锁住的东西

当一个系统被允许动钱，攻击面的形状就变了。传统的信息安全关心“数据会不会泄露”；代理时代还要关心“权限会不会被误用”。后者更危险，因为它不需要任何非法入侵——只需要一次配置错误。

第一类：数据权利。你用来训练和检索的数据，是否有明确的使用授权？在金融业，这不只是合规问题，还是产品可持续性问题：一份来源不清的数据集，可能在产品跑通之后被迫下线，让整条闭环失效。数据权利清单应当在立项时建立，而不是在法务审查时补齐。

第二类：访问权限。代理需要的权限往往比人更宽——它要能读多个系统、调多个接口。最常见的错误是把便利当默认：给代理一个高权限账号，然后靠提示词约束它的行为。**提示词不是权限边界**。真正的边界必须在接口层、在令牌的作用域里，而不是在自然语言里。

第三类：审计与密钥。决策链必须能被完整复现：输入是什么、检索到了什么、模型版本与提示词版本是什么、权限快照是什么、最终执行了什么。这些证据的完整性本身需要被保护——如果日志可以被写日志的那个系统修改，它在举证时就没有价值。

把三类合起来，得到一个对产品设计的直接要求：**治理能力必须在架构里，不能在流程里**。写在制度文件里的“操作规范”在代理面前几乎无效，因为代理不读制度文件，它只受接口和令牌的约束。

新的攻击面
不是“数据泄露”，是“权限误用”。它不需要入侵，一次配置错误就足够了。

提示词不是权限边界
这是本书认为最普遍、也最危险的一个工程错误。边界必须在令牌作用域里。

日志的可信性
如果日志可以被产生它的系统修改，它在举证场景下没有价值。不可篡改是审计事件的最低要求。

一句话原则
治理在架构里，不在流程里。代理不读制度文件。

图 b.1 · 三类锁：常见错误与正确做法

类别	常见错误	正确做法	失败时的后果
数据权利	先做产品，再补授权；混用来源不清的语料	立项即建数据权利清单，标注来源、授权范围与到期时间	产品被迫下线，闭环失效
访问权限	给代理高权限账号，用提示词约束行为	最小权限令牌，作用域含额度、对手方、有效期	越权操作，且难以归因
审计与密钥	只记结果不记过程；日志与业务系统同库同权限	独立不可篡改的事件总线，版本化模型与提示词，权限快照	无法举证，责任无法划分

三行的共同点：错误做法在演示阶段完全不会暴露问题，只在生产事故发生后才显现。这正是它们普遍存在的原因。

b.2 集中度：被忽略的系统性风险

单家机构的权限配置错误是产品缺陷，可以靠工程规范解决。真正难处理的是另一类问题：**整个行业依赖同一批供应商**。

这不是一个理论担忧。英国监管调查显示，**三分之一的 AI 用例是第三方实现**，且其中 16% 被评为高重要性。^[4] 金融稳定理事会也已明确提示：算力与模型供应的集中、对第三方的依赖、模型风险、数据质量、网络攻击，以及市场同质性。^{[7][8]} 其中最容易被产品团队忽略的是最后一项——当大量机构使用相似的模型、相似的提示词、相似的数据源，它们的判断会同时出错，而且是**朝同一个方向出错**。

这与传统的模型风险有本质区别。一个银行自研的信用模型失效，损失局限于这家银行；如果全行业的反欺诈系统都建立在同几个基础模型上，一次共同的失效模式就可能同时打开许多家的口子。金融业过去在评级机构、在风险模型上都经历过类似的教训。

目前对这类风险的定价几乎是零。采购流程会评估供应商的财务稳定性和信息安全资质，但很少评估**“如果这家供应商同时服务了我的十个同业，会发生什么”**。这个问题短期内不会自发解决，因为它对任何单一买方都不是最优先的。

我的判断是：**集中度将成为下一轮金融科技监管的重点议题之一，并且会以采购要求的形式落到供应商头上**。具体形态可能包括：要求模型来源多样性、要求可切换性证明、要求披露上游依赖、以及对关键第三方实施直接监管。对产品团队来说，这意味着“可替换性”会从一个谈判劣势变成一个卖点。

这里有一个反直觉的商业含义。多数供应商本能地想制造锁定，因为锁定意味着续费。但在这个方向上，**能证明自己可以被替换的供应商，反而更容易被选中**——因为买方的合规部门需要这份证明。把退出机制产品化，是少数几个“对客户好也对自己好”的设计。

同质化共振

相似模型 + 相似数据 = 同时朝同一个方向出错。这是 FSB 单列提示的风险，也是产品团队最少考虑的。^[7]

历史上的同构问题

金融业在评级与风险模型上都经历过“大家用同一套方法”的教训。这类风险的特征是：平时看不见，出现时同时出现。

集中度不会自发解决

它对任何单一买方都不是最优先事项，因此只能靠监管或行业标准推动。

反直觉的卖点

能证明“我可以被替换”的供应商更容易中标。退出机制是少数对双方都有利的设计。

图 b.2 · 集中度的三种表现形式与各自的应对

集中在哪里	失效时会发生什么	买方可以要求什么	供应商可以卖什么
算力与基础模型	多家机构的同类判断同时退化	模型来源多样性、可切换性证明	多模型路由与一致性保障
数据与知识源	同一份错误数据污染全行业结论	数据来源披露与交叉验证	独立数据核验服务
中间件与代理框架	同一个漏洞在多家同时可被利用	依赖清单、漏洞响应承诺	可审计的依赖治理与应急演练

三行的共同结构：买方需要的东西，恰好就是供应商可以产品化并单独定价的东西。这是治理层商业化最直接的一条路径。

可托付性问题

如何让一个你不完全理解的系统去动钱？这个问题听上去很哲学，但金融业不需要回答它的哲学形态，只需要回答它的工程与合同形态。这一节论证：可托付性是一个产品问题，而且已经有可用的解法。

本 节 主 张

可托付性不来自“让模型更可靠”，而来自把不可靠的组件放进一个可靠的结构里：额度、熔断、双轨校验、人审触发与可回滚执行。这套结构的设计能力，是未来十年最稀缺的产品能力。

- c.1

不要修模型，要修结构
- c.2

五个结构性组件
- c.3

把它写进合同

c.1 不要修模型，要修结构

面对“模型可能出错”这个事实，工程团队的第一反应通常是让模型少出错：更好的提示、更多的微调、更强的检索。这条路有价值，但它有一个致命的性质——它永远不会到达零。而金融业需要的不是零错误，是**错误发生时后果可控**。

这个区别决定了两种完全不同的产品哲学。第一种试图让组件足够可靠，第二种承认组件不可靠、转而设计一个能容纳不可靠组件的结构。**金融业本身就是第二种哲学的产物**：复式记账假设记账员会出错，双人复核假设一个人会出错，限额假设判断会出错，清算与对账假设传输会出错。

所以正确的问题不是“这个模型准确率够不够高”，而是**“当它错的时候，谁会先发现、损失有多大、能不能撤回”**。这三个问题的答案，比准确率高两个点重要得多。

这也带来一个让工程团队不太舒服的结论：**可托付性的绝大部分工作不在模型侧**。它在额度设计、在触发规则、在回滚路径、在事件留痕、在与人的交接界面。这些工作不产生炫目的演示，但它们是 L1 与 L2 之间唯一的桥。

在这一点上，Intuit 的做法值得注意：它没有假装 AI 可以取代税务专家，而是把注册会计师与税务专家的复核明确做进产品与服务里。^{[19][20]} 这看起来像是承认技术不足，实际上是用**一个结构性组件买下了进入高责任场景的资格**。

核心区别
不是“让错误不发生”，而是“让错误发生时后果可控”。金融业整套制度都建立在第二种哲学上。

三个替代准确率的问题
谁先发现？损失多大？能否撤回？这三个答案决定一个场景能不能跨过 L2。

不舒服的结论
可托付性的大部分工作不在模型侧。它不产生炫目演示，却是 L1 到 L2 唯一的桥。

把人审做进产品
不是承认技术不足，是用结构性组件买下高责任场景的准入资格。

图 c.1 · 两种产品哲学的对照

维度	让组件更可靠	让结构容纳不可靠	金融业选哪个
工作重心	提示、微调、检索、评测	额度、熔断、双轨、回滚、留痕	后者为主，前者为辅
收敛性	渐近改善，永不到零	后果上界可被显式设定	后者
可谈判性	难以写进合同	每一项都可写成条款	后者
对监管的可解释性	依赖模型可解释性研究	依赖流程与证据链	后者

这不是说模型质量不重要，而是说在金融场景里，模型质量决定产品好不好用，结构设计决定产品能不能上线。

c.2 五个结构性组件

把上一节的原则具体化，可托付性由五个组件构成。它们不是可选项，而是一个最小完备集——缺任何一个，系统都无法安全地跨过 L2。

一、额度。单笔上限、单日累计上限、单对手方上限。额度的作用不是防止错误，而是**为错误的总规模设定一个可承受的上界**。它应当可以按客户、按场景、按时间动态调整，并且调整本身要留痕。

二、熔断。当异常率、金额分布或拒绝率偏离基线到一定程度，自动停止执行并转人工。熔断的关键不是阈值多精确，而是它必须**由系统自己触发**，不能依赖有人正好在看监控。

三、双轨校验。用一条与主模型独立的路径复核关键决策——可以是规则引擎、传统模型，或者一个不同来源的模型。独立性比准确性更重要：**两条同源的路径会同时犯同一个错误**。

四、人审触发。把“什么时候需要人”写成可判定的规则，而不是“重要时人工确认”。可用的触发条件包括：置信度低于阈值、金额超过某档、客户等级、历史异常标记、以及新对手方首次交易。

五、可回滚执行。优先选择可撤销的动作形态：预授权而非直接扣款、草稿而非提交、冻结而非划转。当动作不可撤销时，人审触发条件必须显著收紧。

这五项之间存在一个重要的权衡：**收紧任何一项都会降低自动化率**。因此产品设计的核心工作，是在给定的风险预算下找到自动化率最高的组合——这是一个可以量化、可以迭代、可以向客户展示的优化问题，也正是这类产品真正的技术含量所在。

最小完备集

额度、熔断、双轨、人审触发、可回滚。缺一项都无法安全跨过 L2。

额度的真实作用

不是防错，是给错误的总规模设上界。这是唯一能向风险委员会解释清楚的东西。

独立性 > 准确性

双轨校验若与主路径同源，等于没有校验——它们会同时犯同一个错误。

真正的技术含量

在给定风险预算下最大化自动化率。这是可量化、可迭代、可展示的优化问题。

图 c.2 · 五个组件与它们各自防住的失败模式

组件	防住什么	防不住什么	调紧的代价
额度	单次与累计损失失控	高频小额的持续渗漏	大额业务无法自动化
熔断	系统性偏移与突发漂移	缓慢的、在基线内的退化	误触发导致业务中断
双轨校验	单一路径的系统性错误	两条路径共有的盲区	成本翻倍，延迟上升
人审触发	高风险个案	人本身的疲劳与形式化复核	人力成本回升，收益被抵消
可回滚执行	已发生动作的后果	时间敏感、无法撤销的场景	用户体验变差，链路变长

“防不住什么”这一列往往比“防住什么”更重要——它定义了残余风险，而残余风险正是保险与赔付条款需要覆盖的部分。

c.3 把它写进合同

五个组件只存在于代码里时是工程细节，出现在合同里才是商业资产。这是技术团队最不习惯、却最关键的一步跨越。

原因很直接：买方的采购、风控与法务需要一个可以签字的东西。“我们的系统很稳健”无法签字，“单笔执行上限一万元、异常率超过基线两倍自动熔断、超过五万元强制人审、错误按此赔付上限”可以签字。**把技术能力翻译成条款，本质上是在替客户完成他们内部的立项论证。**

更重要的是，条款化会反过来改进产品：当你必须承诺赔付上限时，你会立刻意识到哪些残余风险是你不愿承担的——那正是产品下一步该做的地方。**合同是最诚实的路线图。**

需要写清的条款有六项。它们与 c.2 的五个组件不是一一对应，而是把组件、证据与后果绑在一起。

其中最容易被忽略的是**基线与评测口径**。没有双方认可的人工基线，任何关于“效果提升”的主张都只是市场语言；而一旦基线被写进合同，结果定价才在法律上可执行。这一项通常需要在试点期就完成，事后补几乎不可能——因为那时人工流程已经被改变，基线无法回溯测量。

退出与数据返还同时也是定价工具：愿意承诺完整退出机制的供应商可以要更高的单价，因为买方省下的是一整套供应商风险评估成本。

从能用到能卖

五个组件写在代码里是工程细节，写进合同才是商业资产。

替客户完成立项论证

采购、风控与法务需要能签字的东西。条款化就是把技术能力翻译成他们能用的语言。

合同是最诚实的路线图

你不愿承诺赔付的那部分残余风险，就是产品下一步该做的地方。

基线必须在试点期建立

事后无法回溯测量——那时人工流程已经被改变。这是最常见、也最致命的疏漏。

图 c.3 · 六项必写条款与它们各自绑定的组件

条款	要写清什么	绑定的组件	不写的后果
适用范围	哪些客户、单据、金额区间在范围内	场景边界	范围蔓延，责任无边界
额度与限权	单笔、单日、单对手方上限与调整流程	额度	损失规模无上界
人审触发条件	可判定的规则，而非“重要时确认”	人审触发	复核形式化，形同虚设
基线与评测口径	人工基线取数方式、评测集归属与复核频率	双轨校验	结果定价无法执行
失败赔付边界	错误分级、赔付上限、除外责任	熔断与回滚	纠纷时无依据，关系破裂
退出与数据返还	导出格式、资产归属、过渡期长度	可替换性	客户不敢深度接入

建议把这六项做成标准附件，而不是每次逐条谈判。标准化本身就是一种能力证明，会显著缩短大机构的采购周期。

我可能错在哪里

本节假设买方愿意就 AI 决策签署带赔付的条款。但也可能出现相反的均衡：买方坚持“责任全在供应商”，而供应商无力承担，于是双方退回到低额度、低价值的试点，长期无法规模化。若三年内市场上仍看不到成型的赔付条款范式，这一节的路径就需要重估。

本节证伪条件

到 2029 年，若行业内仍无可参照的 AI 决策赔付条款范式，或保险机构仍拒绝为此类风险提供承保，则可托付性的商业化路径失败。

标准之争

轨道、账本与可托付性都是可以在一家公司内部解决的问题。标准不是。谁来定义代理的授权语义、拒付责任与跨境互认，决定了未来十年谁在收租、谁在付费——而这场争夺目前几乎没有公开讨论。

本 节 主 张

中美欧正在形成三套逻辑不同的治理框架：中国按主体与生命周期管，美国按用途与重要性管，欧盟按风险等级管。三者短期不会统一，因此“合规适配能力”本身会成为一门可以独立售卖的生意。

- d.1

三套治理逻辑
- d.2

代理支付的标准空白
- d.3

中国能拿到什么

d.1 三套治理逻辑

把三地的监管文件放在一起看，会发现方向惊人地一致：按风险分级、覆盖全生命周期、要求可追溯。但**组织这套要求的逻辑完全不同**，而差异恰恰出现在对产品设计影响最大的地方。

中国按主体与生命周期组织。2026 年金融监管总局的 32 项意见明确“谁使用谁负责”，强调自主可控，要求覆盖需求、数据、开发、部署、运行、退出的完整链条，并对高风险场景重点监管。^[10] 它的抓手是**使用方**：金融机构对其使用的 AI 负全责，供应商通过机构的合规要求间接受约束。

美国按用途与重要性组织。财政部的金融服务 AI 风险管理框架与修订后的模型风险指南，沿用既有的风险管理体系，强调用途分层、重要性判断、第三方风险、独立验证、透明与韧性。^[11] 它的抓手是**风险的重要性**：越重要的模型，验证与治理要求越高，而重要性由机构自己论证、由监管检查。

欧盟按风险等级组织。AI Act 把信用评分、部分保险定价等列入可能的高风险类别，要求数据质量、日志留存、人类监督与稳健性；DORA 则已经覆盖 ICT 韧性与关键第三方风险。^{[12][13]} 它的抓手是**系统本身的分类**：先判定这是哪一类 AI，再套用对应的义务清单。

差异的实际后果非常具体。同一个产品要进入三个市场，需要回答三个不同的问题：在中国是“使用它的机构能否证明全生命周期可控”，在美国是“这个用途的重要性有多高、验证是否独立”，在欧盟是“它属于哪一类、对应义务是否齐备”。**这三个问题的证据材料不能互相替代。**

由此推出一个商业结论：**合规适配会成为一个独立的产品层**。它不是把文档翻译成三种语言，而是把同一套能力映射到三套不同的证据结构上——同样的日志，需要以三种方式组织和呈现。愿意把这件事产品化的公司，能把别人的成本变成自己的收入。

方向一致，逻辑不同

三地都要求分级、全生命周期与可追溯，但组织方式不同：中国管主体，美国管重要性，欧盟管分类。

为什么差异重要

它决定了你要准备哪种证据。同一份日志在三地需要以三种方式组织，不能互相替代。

合规适配器

把同一套能力映射到三套证据结构上。这是本书认为最清晰的一个可独立售卖的产品机会。

不要指望统一

三套逻辑背后是三种不同的监管哲学与政治结构。短期趋同的是方向，不是接口。

图 d.1 · 三套治理逻辑的产品含义

辖区	组织逻辑	核心要求	对产品的具体影响	你需要准备的证据
中国	按使用主体与全生命周期	谁使用谁负责；自主可控；需求到退出全链条留痕 ^[10]	私有化与国产化适配成为准入前提	开发与运行的完整过程记录
美国	按用途与重要性分层	用途分层、独立验证、第三方风险、透明与韧性 ^[11]	需要可复现的验证文档与模型清单	独立验证报告与重要性论证
欧盟	按 AI 系统的风险分类	高风险场景的数据质量、日志、人类监督、稳健性 ^{[12][13]}	日志留存是硬性功能，非选配	符合性评估与技术文档

三行的“你需要准备的证据”互不重叠，这正是合规适配器的价值所在：一次采集，三种组织方式。

d.2 代理支付的标准空白

三地的框架都在讨论“AI 系统应当如何被治理”，但它们几乎都没有回答第二章提出的那个具体问题：**当一个代理代表用户发起交易并出错时，谁赔。**

这不是疏漏，而是时序问题——监管通常在现象具备规模之后才介入。但这个空白期恰恰是**标准形成的窗口**，而标准一旦形成就极难改变。历史上支付领域的多次规则确立都发生在类似的窗口里，先行者的方案往往成为事实标准。

目前有三类主体在尝试填补这个空白，各自的逻辑不同。**支付网络**推动共享令牌与代理商务协议，逻辑是把代理纳入既有的授权与争议体系，尽量少改规则。**平台与生态**推动自有的代理接入方案（如支付 MCP、AI 钱包一类），逻辑是先在自己的生态内跑通，再向外输出。^{[14][16][24]}**模型与终端厂商**则希望代理层保持中立，避免被单一支付方绑定。

三方的诉求存在真实冲突。支付网络希望责任沿用现有规则，这对它有利；平台希望责任留在生态内部，便于自己控制；模型厂商希望责任落在支付侧，因为它们无力承担资金风险。**没有任何一方能单方面定标准**，因此最可能的结果是长期的多标准并存，直到某次规模化事故推动监管介入。

对中国公司来说，这个空白期有一个特殊含义：**执行权的优势只有在标准互认的世界里才能兑现成跨境收入**。如果标准按区域割裂，那么再强的国内执行能力也只是国内资产。这使得参与国际标准讨论——哪怕只是提出可被引用的技术方案——具有超出商业收益的战略价值。

空白期即窗口
监管在现象规模化后才介入。空白期形成的事实标准，往往就是最终标准。

三方诉求真实冲突
支付网络要沿用旧规则，平台要留在生态内，模型厂商要把责任推给支付侧。没有一方能单独定标准。

最可能的结果
多标准并存，直到一次规模化事故推动强制统一。这意味着窗口比多数人预期的更长。

对中国公司的含义
执行权只有在互认的世界里才是跨境资产。参与标准讨论的战略价值超过其直接商业收益。

图 d.2 · 代理交易出错时的四种可能责任分配（目前均无成熟规则）

分配方案	谁承担	谁支持这种方案	主要问题
沿用未授权规则	接受交易的机构或商户	用户与消费者保护方	代理是被授权的，前提不成立
授权即免责	用户自己承担	支付与商户侧	用户无法预见代理的全部行为
代理供应商担责	提供代理的公司	支付网络与平台	模型厂商无力承担资金风险
按授权范围分层	范围内用户担，越权供应商担	本书认为最可能成为主流	需要授权语义的统一表达

第四种方案的前提是“授权范围”必须被机器可读地表达出来。谁的表达方式被广泛采用，谁就掌握了这一层的定义权。

d.3 中国能拿到什么

把前面几节合起来，可以对中国公司在这一轮中的可得位置做一个具体的判断。我认为有三件事是可以争取到的，还有两件大概率争取不到。

可以拿到的第一件：跨境商户场景的代理支付与财资。这一段的客户是华资或面向中国供应链的商户，对中国支付能力有天然依赖；执行权可以延伸，治理能力可以标准化，本地持牌方有共同交付的动机。这是最现实的国际化路径。

可以拿到的第二件：治理层的产品化输出。中国监管对全生命周期留痕、自主可控与退出机制的要求，客观上迫使本土厂商更早建设这套能力。^[10]如果把它做成可独立售卖的模块，而不是每个项目重做一遍，它在其他强监管市场同样有需求——因为要求的**形式**不同，但需要的**证据**高度重叠。

可以拿到的第三件：中文与本地语料上的领域评测资产。公开的领域评测集是一种低成本、高杠杆的标准影响力。同花顺开源 BizFinBench、建立中文金融问答评测的做法，方向是对的——^[23] 评测集会成为采购环节的引用对象，而被引用就是话语权。

大概率拿不到的第一件：全球通用的授权语义标准。这一层与支付网络的既有规则、与各地的消费者保护制度深度绑定，主导权大概率留在既有的国际支付与监管体系内。现实的目标是“被兼容”，而不是“被采纳”。

大概率拿不到的第二件：直接复制国内零售金融打法的海外业务。牌照、征信体系、消费者保护规则与获客成本都不同，过往多次尝试的经验也不支持这条路。**与其复制零售，不如攻商户。**

这五条合起来给出的战略姿态是：**在执行层守住已有优势，在治理层主动进攻，在标准层争取被兼容。**这比“全面对标”更现实，也更可能在十年后留下真实的资产。

最现实的国际化路径

跨境商户的支付、财资、风控与合规。执行权可延伸，治理可标准化，本地伙伴有动机。

形式不同，证据重叠

三地要求的呈现形式不同，但底层需要采集的证据高度一致。这正是治理模块可以跨市场复用的原因。

评测集即话语权

被采购文件引用的评测集，会反过来定义“什么算合格”。这是低成本的标准影响力。^[23]

现实的目标是被兼容

在授权语义这一层，争取“被采纳”不现实；确保“被兼容”才是可达成的目标。

图 d.3 · 三争与两不争：中国公司的可得位置

姿态	目标	凭什么	成功的判据
争	跨境商户的代理支付与财资	执行权可延伸，本地持牌方有共同交付动机	非项目制的标准产品收入占比
争	治理层的产品化输出	国内监管要求迫使能力提前建成，且三地证据高度重叠 ^[10]	治理模块能否独立定价并被复购
争	中文与本地语料的领域评测资产	公开评测集是低成本、高杠杆的标准影响力 ^[23]	是否被采购文件与监管问答引用
不争	全球通用的授权语义标准	与既有支付规则和各地消保制度深度绑定	目标改为“被兼容”而非“被采纳”
不争	直接复制国内零售金融的海外业务	牌照、征信、消保与获客成本结构完全不同	不投入即为成功

这张表的意义在于明确“不争什么”。战略的多数失败不是选错了方向，而是同时选了太多方向。

监管入场的形态

关于 AI 监管的公共讨论，大多围绕“会不会被禁止”。在金融业，这是个错误的问题——金融业从来禁止技术，它只决定谁被允许使用、在什么条件下使用。这一章推演监管实际会以什么形态入场，以及这对产品意味着什么。

本章主张

监管不会以禁令的形式出现，而会以采购准入的形式出现。当评测、日志、权限、回退与退出被写进招标文件，市场就会在没有任何禁令的情况下完成一次彻底的供应商洗牌。

4.1

不是禁止，是准入

4.2

三种可能的制度安排

4.1 不是禁止，是准入

金融监管很少直接禁止一项技术。它更常用的手段是**提高使用它的条件**——要求验证、要求留痕、要求资本、要求人审。效果上，这与部分禁止相似，但形式完全不同：技术不违法，只是使用它的成本被显著提高了。

这个区别对产品团队至关重要。如果你预期的是禁令，你的应对是游说与观望；如果你预期的是准入条件，你的应对应该是**提前把条件做成功能**。后者是一个可以现在就动手的工程任务。

已经能看到这个形态的雏形。美国财政部 2026 年 2 月发布的 FS AI RMF 本身不具法律约束力，却把 AI 治理拆成了**230 项控制目标**，按治理、映射、度量、管理四类排布。^[11] 这类“软法”的真正作用不是处罚，而是定义了检查人员会问什么——而检查人员问什么，采购清单上就会写什么。三地文件共同要求的分级、全生命周期、可追溯、第三方风险与人类监督，最终都会落成清单上的具体项目。^{[10][11][12]} 一旦落成，不满足的供应商不是被罚款，而是**连投标资格都没有**。

这就是我说“洗牌在没有禁令的情况下发生”的意思。假设某年起，主要金融机构的招标文件统一要求提供：独立的评测报告、不可篡改的审计事件、细粒度权限模型、经过演练的回退方案、以及可执行的退出与数据返还条款。绝大多数今天活跃的 AI 供应商，会在这一页上直接出局——不是因为产品不好，而是因为这些东西从来不在他们的路线图上。

反过来说，这也是本书认为最明确的一个机会。**准入条件是可以提前知道的**：监管文件已经公开，方向已经一致，剩下的只是把它们翻译成能与文档。愿意在还没有人要求的时候就做完这件事的团队，会在洗牌那一刻拥有一个别人需要两年才能补上的差距。

监管的真实手段

不是禁止，是提高使用条件。技术不违法，只是用它的成本被抬高。

两种预期，两种应对

预期禁令 → 游说与观望；预期准入 → 提前把条件做成功能。后者今天就能动手。

出局的方式

不是被罚款，是连投标资格都没有。这种淘汰没有申诉环节。

为什么这是最明确的机会

准入条件已经公开在监管文件里。这是少见的、可以提前两年知道答案的考试。

图 4.1 · 从监管原则到招标条款：一条可预测的翻译链

监管原则（已公开）	会变成什么招标条款	对应的产品功能	现在做的成本
分级分类管理	按场景风险等级提供差异化控制措施	分级授权与场景化额度	低
全生命周期可追溯	提供不可篡改的决策链记录，留存 N 年	独立审计事件总线	中，但越晚越贵
独立验证	提供第三方或独立团队的评测报告	标准化评测集与报告生成	中
人类监督	明确人审触发条件与复核记录	可判定的人审规则引擎	低
第三方风险与韧性	披露上游依赖，提供切换与退出方案	依赖清单与退出机制产品化	高，但可独立收费

最后一列是关键：这些功能的建设成本随时间上升（数据越多，补留痕越难），而收益随监管落地而跃升。这是一个明确的“早做便宜”的结构。

4.2 三种可能的制度安排

准入条件之外，还有三种更重的制度安排可能出现。它们的共同点是：都会把某些今天属于企业内部的事情，变成行业层面的公共设施。

第一种：行业级评测与认证。由监管、行业协会或授权的第三方维护公共评测集，供应商需通过认证才能进入某类场景。这在其他受监管行业有成熟先例。它的好处是降低每个买方的验证成本；风险是评测集本身会被过度优化，变成新的应试。

第二种：强制事故披露。要求机构报告 AI 相关的生产事故，并在行业内共享去标识化的失败模式。这是保险精算所需数据的最可能来源，因此它同时解锁了第一章讨论的保险窗口。**如果要挑一个最值得盯的制度信号，我会挑这个。**

第三种：关键第三方直接监管。当某些供应商的失效会影响多家机构时，监管可能绕过“机构对供应商负责”的间接路径，直接对供应商提出要求。欧盟的 DORA 已经在 ICT 韧性方向上建立了这类机制。^[13]这对头部供应商是双刃剑：合规成本上升，但门槛也随之抬高。

三者的时序大概率是：准入条件最先（已经在发生），强制披露其次，直接监管最后且只针对少数关键供应商。对产品团队而言，前两者需要主动准备，第三者只与极少数公司相关。

这里值得区分两种常见的误解。第一种是把监管当作纯粹的成本——事实上，准入条件同时也是**竞争壁垒**：它把不愿意做这些事的对手挡在门外，而这些事你迟早都要做。第二种是把监管当作可以事后补的文档工作——但审计留痕、权限模型与退出机制都是架构决策，**越晚改动成本越高，而且是指数级的。**

还有一个时间上的判断值得记下来：制度安排通常在**第一次有规模的故事之后**加速。这意味着行业的实际节奏可能不由监管主动推进，而由某一次公开事故触发。因此，把“事故发生后我们需要在四十八小时内拿出什么证据”作为设计输入，比预测监管文件的发布时间更有用。

我可能错在哪里

本章假设监管的方向是持续收紧。但监管也受产业竞争压力影响：如果某个主要经济体判断严格治理正在损害本国竞争力，它可能选择放松，并引发其他辖区的跟随。**那将从根本上改变本书的结论**——治理能力的溢价会消失，速度与规模重新成为唯一变量。

最值得盯的信号

强制事故披露。它是保险精算数据的来源，因而是解锁 L3 的关键一步。

认证的副作用

公共评测集一旦成为准入门槛，就会被过度优化。这是所有标准化考试的通病，无法避免，只能定期更新。

DORA 的先例

欧盟已建立对关键 ICT 第三方的直接监管机制。AI 供应链走同一条路的可能性不低。^[13]

本章证伪条件

若任一主要经济体明确以“保持竞争力”为由放松金融 AI 治理要求，且其他辖区跟随，则本章与全文对治理溢价的判断需整体下修。

第五章 六个赌注

推演的价值不在于它听起来是否合理，而在于它能否被检验。下面六条是本书的全部主张压缩成的可下注形式：每一条都有明确的时点、明确的证伪条件，以及如果它成立、你现在就该做的事。

怎么用这份清单
按季度检查证伪条件。任一条被证伪时，修正的应当是对应的行动，而不是整个框架。

1	治理栈会先于模型能力成为采购门槛 评测、日志、权限、回退与退出会以独立条款形式进入主流招标文件，且不满足者失去投标资格。 证伪：到 2029 年，主流金融机构招标仍只比较模型基准与价格。	2026 — 2028 高置信
2	可托付金额会在若干场景明确离开零 至少在退款、对账、催收或反欺诈中的一类，出现无人逐笔复核、带额度与回滚的常规执行。 证伪：到 2029 年底，仍无任何一类金融动作被普遍允许无人逐笔复核执行。	2026 — 2029 高置信
3	强制事故披露会先于保险产品出现 监管要求报告 AI 生产事故并共享失败模式，随后才会出现可承保的 AI 决策责任险。 证伪：保险产品在任意强制披露机制之前成规模出现。	2027 — 2031 中置信
4	代理支付将长期多标准并存 授权语义与拒付责任不会在十年内统一，跨生态互认停留在双边协议层面。 证伪：出现被主要支付网络与主要平台共同采纳的单一授权标准。	2027 — 2035 中置信
5	价值向执行层、事实层与治理层三分 不会出现单一的金融 AI 操作系统；三层各有在位者，且治理层最晚成型、最被低估。 证伪：某一玩家同时稳固占据执行与事实两层，且治理能力被内化为其附属功能。	2028 — 2035 中置信
6	全面自主金融不会在 2035 年前成为主流 无人复核的授信、投顾与交易执行将长期保持额度与场景边界，边界随事故率动态调整。 证伪：任一主要市场允许无额度上限的自主授信或自主交易执行成为常规业务。	2030 — 2035 高置信

这六条不是彼此独立的。**赌注 3 是整串的枢纽**：强制事故披露一旦发生，保险精算就有了数据，赌注 2 的经济学随之成立，赌注 1 的采购条款也会被迫加速。反过来，如果披露机制迟迟不出现，2 和 1 都会显著推迟，而 6 会更加稳固。

枢纽在第 3 条
强制披露 → 精算数据 → 保险 → L3 经济学成立。盯这一条，胜过盯其余五条。

赌注 4 与 5 则构成另一组：多标准并存意味着没有任何一方能垄断授权语义，这恰恰保证了三层结构不会塌缩成一层。**如果哪天出现了被普遍采纳的单一标准，赌注 5 也需要重估**——因为定标准的那一方会顺势向上下游扩张。

联动的证伪
赌注 4 若被证伪，赌注 5 也需重估：定标准者会顺势向上下游扩张。

5.2 如果你在 2026 年做产品

把六个赌注翻译成行动，对不同位置的人意味着不同的事。

如果你在创业。不要做通用金融助手。选一个错误可观测、可撤销的场景，把额度、熔断、双轨、人审触发与回滚五件事做完，然后去找三家愿意和你一起承担第一次事故的机构。你的护城河不会来自模型，只会来自那三家机构愿意把权限交给你这件事本身。

如果你在大机构做产品。你最稀缺的资源不是预算，是**可归因的基线**。在做任何 AI 项目之前，先花两个月把人工基线和金标准评测集建起来——没有它，你三年后仍然无法回答“这个投入值不值”。同时，把治理能力当作产品路线图的一部分而不是合规的尾巴。

如果你在投资或战略岗位。把“这家公司握有哪几种控制权”作为第一层筛选，把“它的优势会不会被下一代模型抹平”作为第二层。对纯判断层的公司要求更高的短期回报，因为它们站在成本崩塌的那一侧。

如果你在监管或政策侧。本书认为最有价值的一步是推动强制事故披露与去标识化的失败模式共享。它同时解决三个问题：让机构互相学习、让保险可以定价、让集中度风险变得可见。

四类人的共同点是：**都不需要等技术再进步一步**。上面每一项建议今天就能开始，而且它们的成本随时间上升、收益随责任转移而跃升。这是一个典型的“早做便宜”的结构——而多数组织会等到不得不做的时候才做。

结语

这篇文章的全部论证可以压缩成一句话：**金融科技的下一个十年，不会由谁的模型更强决定，而会由谁被允许在无人看着的时候动钱决定。**

这个变量今天几乎为零，所以没有人为它建模，也没有人为它定价。但它不会永远为零——因为它离开零所需要的东西，没有一样是不可获得的：额度可以设计，熔断可以实现，审计可以留痕，责任可以定价，保险可以精算。**它们只是还没有被系统地做完。**

谁先把这些做完，谁就会在下一次责任转移发生时，站在被允许的那一边。而那一刻到来时，市场会突然发现自己一直在为错误的东西定价。

创业者

护城河不来自模型，来自“有机构愿意把权限交给你”这件事本身。

大机构产品经理

最稀缺的不是预算，是可归因的基线。没有基线，三年后你依然无法证明任何事。

投资与战略

第一层筛选：握有哪几种控制权。第二层筛选：优势会不会被下一代模型抹平。

政策侧

强制事故披露一步解三题：互相学习、保险定价、集中度可见。

附录 A 跟踪清单与术语

表 A.1 · 按季度跟踪的十个信号

#	信号	在哪里看	它一旦出现，说明什么
1	招标文件出现独立的治理条款	公开招标公告、主服务协议模板	准入洗牌开始，赌注 1 兑现
2	出现针对 AI 决策错误的独立险种	保险产品备案、行业公告	L2 → L3 的经济学成立
3	强制 AI 事故报告或失败模式共享机制	监管通知、行业自律规则	保险窗口即将打开
4	代理支付的授权与拒付规则首次成文	支付网络规则手册、平台开发者协议	标准之争进入实质阶段
5	AI 模块的独立收入、付费渗透与续费率被披露	年报、季报、投资者交流	商业证明从叙事变成事实
6	关键第三方被纳入直接监管范围	监管名单、法规修订	集中度风险被正式定价
7	公共领域评测集被采购文件引用	招标技术要求、行业标准	评测资产转化为话语权
8	出现首例代理越权交易的公开纠纷或判例	司法公开、监管处罚	责任分配方案开始收敛
9	生产事故率、模型漂移或供应商集中度显著上升	监管报告、行业调查	时间表可能整体推迟
10	结果付费从营销口号变成可审计的合同条款	合同范本、客户案例	定价模式完成迁移

术语与口径

可托付金额上限。一个系统在无人逐笔复核的前提下，被允许发起的资金动作金额上限。本书的核心变量，按场景分别取值。

自动化深度 L0—L4。按"能否自主产出结论、能否自主执行、后果由谁承担"划分的五级框架，定义见 1.1 节。

系统记录。某类业务事实的权威存放处（账本、持仓、申报记录）。替换它需要迁移历史数据与流程配置。

持续结果标签。随业务自动回流的真实结果（是否拒付、是否坏账、是否被采纳），区别于一次性采购或标注的静态语料。

治理栈。评测集、日志、权限、红队、回退与供应商退出机制的总称。本书认为它正从成本项变为准入项。

委托链。用户 → 企业 → 代理 → 动作的授权链条。代理时代身份验证的对象。

取值方式

可托付金额上限按场景分别取值，不存在一个全公司的统一数字。任何声称有统一数字的说法都应被怀疑。

与常见术语的区别

本书不使用"自动化率"，因为它会把 L0 的报表生成与 L2 的自动执行混为一谈。

附录 B 资料来源

证据等级：监管与法规文件、审计年报优先；官方产品页用于确认功能与自报规模；学术与国际组织报告用于机制判断。公司披露的效率、交易与用户数字不视为第三方验证。市场支出预测只用于判断方向，不作为估值依据。

本书的推演部分
凡未标注来源的判断，均为作者推演，且在正文中标明触发与证伪条件。

#	来源	类型	用于
[1]	毛泽东，《反对本本主义》，1930	方法论	调查方法
[2]	毛泽东，《〈农村调查〉的序言和跋》，1941	方法论	调查方法
[3]	毛泽东，《实践论》，1937	方法论	判断方法
[4]	BoE / FCA, AI in UK Financial Services, 2024（118 家机构）	监管调查	采用率与自主决策占比
[5]	World Economic Forum, Artificial Intelligence in Financial Services, 2025	国际组织	支出规模与方向
[6]	BIS, Intelligent Financial System: How AI is Transforming Finance, 2024	国际组织	产业结构
[7]	Financial Stability Board, The Financial Stability Implications of AI, 2024	国际组织	系统性风险与同质化
[8]	FSB, Sound Practices for Responsible Adoption of AI — Consultation, 2026	国际组织	治理实践
[9]	中国信通院，《数字金融创新发展研究报告（2025 年）》，2026	研究机构	中国产业现状
[10]	国家金融监督管理总局，《关于银行业保险业人工智能安全开发应用的指导意见》，2026-06-18	监管文件	中国治理逻辑
[11]	U.S. Treasury, Financial Services AI RMF + AI Lexicon, 2026-02-19（230 项控制目标，非约束性）	监管框架	美国治理逻辑
[12]	European Commission, AI Act — Regulatory Framework and Timeline, 2026	法规	欧盟风险分级
[13]	EUR-Lex, Digital Operational Resilience Act (DORA), applicable since 2025	法规	第三方与韧性
[14]	蚂蚁集团，《2025 世界人工智能大会产品与技术进展》，2025	公司披露	代理支付方向
[15]	Ant Group, 2024 Sustainability Report Highlights, 2025	公司披露	全球覆盖规模
[16]	Stripe, 2025 Annual Letter, 2026	公司披露	支付量与代理商务
[17]	Stripe, 2025 Annual Letter：自适应受理于 2024 年恢复约 60 亿美元误拒交易	公司披露	误拒恢复数据
[18]	Stripe, Radar 产品页，2026-09：70 万亿+ 数据点、平均减少 32% 欺诈	官方产品页	网络数据规模
[19]	Intuit, FY2026 全年业绩公告，2026-08-25：收入 \$21.4B（+14%）	公司财报	收入与业务结构
[20]	Intuit, Virtual Team of AI Agents for QuickBooks, 2025	官方产品页	Agent 与专家复核
[21]	Bloomberg Professional, AI on Bloomberg / ASKB, accessed 2026-09	官方产品页	数据与工作流
[22]	Wu et al., BloombergGPT: A Large Language Model for Finance, arXiv, 2023	学术	领域模型先发认知
[23]	同花顺，《2025 年年度报告》，2026：收入 60.29 亿元、归母净利 32.05 亿元	审计年报	中国投研与评测资产
[24]	蚂蚁集团，公司主页：AI 支付与集团业务事实，访问于 2026-09	官方产品页	支付 MCP 与 AI 钱包

附录 C 方法、折价规则与研究边界

方法

本书的写法是：先用监管文件、审计年报与国际组织报告确定"已经发生了什么"，再在这些事实上做条件推演，并为每一条推演出可观察的触发与证伪条件。无法被证伪的主张，尽量不写。

本书不预测模型能力，也不依赖任何模型性能假设——全篇恰恰建立在"模型能力持续商品化"这一前提上。若该前提被推翻，第三章 a 的剪刀差论证首先失效。

数据核验声明

书中引用的公开数据已于 **2026-09-11** 逐条比对一手来源：监管调查与法规原文、公司财报与业绩公告、官方产品页。第一版定稿前据此修正了九处陈述，其中三处属实质性错误，修正记录保存在仓库的提交历史中。

但这不等于书中不会再有错。仍需说明四点：一、**公司自报的数字无法独立验证**，本书只用它判断方向，不用它支撑结论；二、官方产品页的数字随时间变动，文中标注的是访问日期当时的口径；三、作者并非金融从业者，对监管文件的理解可能存在偏差；四、凡标注"研究判断"或出现在推演章节中的内容，都是作者的推论，不是事实陈述。

如果你发现任何错误，欢迎在仓库提出，勘误会记入版本历史。一份带着已知错误流传的研究，比一份承认自己可能出错的研究更危险。

表 C.1 · 第一版定稿前的三处实质性修正

早期版本的说法	核验结果	现在的表述
受监管环节渗透位次 9/21	BoE/FCA 2024 报告中不存在该排名，报告未按 21 个业务领域排序	改用该报告的真实数据：完全自主决策的用例只有 2%
Radar 恢复 60 亿美元被拒交易，用户争议率下降 17%	60 亿属自适应受理而非 Radar，且为 2024 年、同比 +60%；17% 未见于公开资料	按公司口径分别表述，Radar 引用其官方的"平均减少 32% 欺诈"
Intuit 每月节省最多 12 小时、回款快 5 天	未能在公开披露中找到出处	改用 FY2026 披露：300 万+ 客户使用 AI 代理，重复使用率 >85%

另有六处为精度与名称修正：Intuit 收入口径、美国监管文件名称与日期、中国指导意见全称与发布日、Alipay+ 覆盖数字、Bloomberg 终端用户数、受访机构家数。

证据折价规则

公司自报的效率提升只用于判断方向；未经审计的收入与用户数不进入结构性结论；媒体估值与融资传闻完全不采用；产品发布数量不计入商业证明；仍处 beta 的功能计入产品能力，不计入商业验证；"覆盖机构数"不等于付费渗透率，凡引用必单列说明。

为什么公开错误清单

把改了什么写出来，读者才知道该重新检查什么。藏起来的修正等于让引用过旧版的人继续错下去。

写作原则

不可证伪的主张尽量不写。这是本书与多数产业预测最主要的区别。

最脆弱的前提

模型能力持续商品化。若某公司建立起持久的金融专用模型优势，剪刀差论证首先失效。

为什么写出错误数量

把"修正了九处、其中三处是实质性错误"写出来，比笼统说一句"数据可能不准"更有用——前者可核对，后者只是免责。

研究边界

本书不是行业名录，不对未上市公司做估值判断，不构成投资建议。文中出现的五家公司仅用于呈现不同类型的产业控制点，不代表它们是各自领域的唯一代表；银行内部自研、保险科技、监管科技与底层模型厂商在产业链讨论中出现，但不作为独立分析对象。

所有关于 2026 年之后的陈述均为条件推演，读者应按季度用新增事实修正判断，特别是附录 A 的十个信号。**如果某一条推演的证伪条件先出现，正确的做法是推翻它，而不是解释它。**

已知的三个盲区

- 一、几乎没有讨论保险业。保险的 AI 应用有自己的结构（核保、理赔、精算监管），与银行和支付的逻辑差异较大，纳入会削弱论证的锐度，但确实构成覆盖缺口。
- 二、假设了渐进的地缘环境。若出现重大的技术出口管制或金融基础设施脱钩，跨境部分的推演需要整体重写。
- 三、以机构视角为主。消费者是否愿意让代理替自己花钱被当作外生变量处理，这可能是全书最大的未检验假设。

更新方式

按季度对照附录 A 的十个信号，只在信号出现时调整判断，不因时间流逝而调整。

勘误

发现错误请在仓库提出。修正会带版本号，旧版本不删除——这样引用过旧版的人知道自己引了什么。

关于本书

《被允许动的钱：金融科技的下一个十年》是一份独立的产业推演。写作目的是把一个通常被叙述为“技术竞赛”的问题，重新表述为一个关于授权、责任与标准的分配问题。全文所有公司事实均来自公开披露，不含任何未公开信息，不构成投资建议。

作者 邹志华，与 Claude（Anthropic）共同撰写。框架、判断与结论由作者确定，结构化写作与排版由 AI 协作完成，事实与推演经作者核对。

版本 第一版，2026 年 9 月 · 资料截至 2026-09-10

仓库 github.com/joshuazou-web/money-ai-is-allowed-to-move